

災害復旧・事業継続計画書

1. 文書管理

本文書は当行の災害復旧（DR）および事業継続計画（BCP）を定めるものである。文書番号 DR-BCP-2024-001、バージョン 4.0、最終改訂日 2024年8月15日とする。管理責任者はリスク管理部 事業継続管理課長であり、改訂には経営会議の承認を要する。

本書は年次で見直しを実施し、組織変更、システム構成変更、または重大インシデント発生時には臨時改訂を行う。配布先は全部門長、システム統括部、および外部監査法人（監査時のみ）とし、社外秘・厳秘として取り扱う。

改訂履歴は文書管理システムにて一元管理し、旧版は改訂日から7年間保管する。バージョン3.0からの主な変更点は、クラウドDR構成の追加、RTO/RPO目標値の見直し、およびリモートワーク環境を考慮した連絡網の更新である。

2. 目的・適用範囲

本計画はFISC安全対策基準 設-9（災害対策）および設-10（業務継続計画）に準拠し、大規模災害・システム障害発生時における当行業務の継続および早期復旧を目的とする。適用範囲は当行の全業務システム、ネットワーク設備、データセンター設備、および関連する外部委託先サービスとする。

想定脅威シナリオとして、(1)首都直下地震（震度7）、(2)大規模停電（72時間以上）、(3)パンデミック（出社率30%以下）、(4)サイバー攻撃（ランサムウェア全面感染）、(5)主要外部委託先のサービス停止、の5パターンを定義する。各シナリオに応じた復旧手順および代替運用手順を本書で規定する。

金融庁「金融機関のシステムリスク管理基準」および「主要行等向けの総合的な監督指針」に基づき、重要な業務を担うシステムの継続性確保について、経営陣の関与のもと適切な態勢を整備する。BCPの有効性は年2回のDR訓練および四半期ごとのリストアテストにより検証する。

3. 業務影響度分析（BIA）

業務影響度分析（Business Impact Analysis）は年次で実施し、各業務システムの重要度を4段階（S/A/B/C）に分類する。評価基準は、(1)顧客影響度、(2)財務影響額、(3)法令・規制違反リスク、(4)レピュテーション影響の4項目を重み付け評価（各25%）する。

Sランク（最重要）業務は、勘定系システム（預金・為替・融資）、対外接続系（全銀ネット・日銀ネット・SWIFT）、およびATMオンラインである。Aランク（重要）業務は、インターネットバンキング、コールセンターシステム、リスク管理システムとする。Bランク業務は情報系（営業支援・経営情報）、Cランク業務は社内OA系とする。

各ランクのシステムについて、停止許容時間（MTO）、目標復旧時間（RTO）、目標復旧時点（RPO）を定義する。SランクのMTOは4時間であり、この時間を超える停止は金融庁への報告義務が生じる。BIAの結果は経営会議に報告し、復旧優先順位の合意を得るものとする。

4. RTO/RPO定義

基幹系システム（Sランク）のRTOは4時間、RPOは1時間と定める。これにより、障害発生から4時間以内にサービスを復旧し、最大1時間分のデータロスを経容範囲とする。勘定系データベースは同期レプリケーションにより実質RPO

0を達成しているが、非同期レプリケーション区間を考慮し公式RPOは1時間とする。

情報系システム（Bランク）のRTOは8時間、RPOは4時間とする。営業支援システム（CRM）および経営情報システム（MIS）は日中帯の利用が中心であり、夜間障害発生時は翌営業日開始までの復旧を目標とする。バックアップは4時間ごとの差分バックアップとし、直近のバックアップ時点からの復旧を前提とする。

チャネル系・公開系システム（Aランク）のRTOは2時間、RPOは15分と定める。インターネットバンキングは24時間365日のサービス提供が求められるため、最も厳しいRPO要件を設定する。AWS側のRDS Multi-AZおよびポイントインタイムリカバリ（5分粒度）によりRPO 15分を確保する。

RTO/RPO目標値は四半期ごとのリストアテストで達成可否を検証し、未達の場合は改善計画を策定する。年2回のDR訓練では実際のフェイルオーバーを実施し、実測値を記録する。直近の訓練（2024年9月）では、基幹系RTO実測値2時間38分、チャネル系RTO実測値1時間12分であった。

5. バックアップ方式

バックアップは3-2-1ルール（データ3コピー、2種類のメディア、1コピーをオフサイト保管）に基づき運用する。日次フルバックアップは毎日02:00に開始し、勘定系データベース（約8TB）のフルバックアップ所要時間は約3時間である。差分バックアップは1時間ごとに実施し、バックアップウィンドウは5分以内に完了する。

オンサイトバックアップはDell PowerStore上のスナップショットとして保管し、30日分を保持する。オフサイトバックアップは(1)大阪DCへのレプリケーション（リアルタイム同期）および(2)AWS S3 Glacier（日次転送）の2系統で実施する。テープバックアップ（LTO-9）は月次で取得し、鉄山（Iron Mountain）の外部保管庫に搬送する。

バックアップデータの保管期間は、日次バックアップ30日、週次バックアップ13週（約3ヶ月）、月次バックアップ7年、年次バックアップ10年とする。法令で定められた保管義務のあるデータ（取引記録等）は10年間保管し、S3 Object Lock（Compliance Mode）により改ざん防止を適用する。

バックアップの完全性検証として、毎月ランダムに選定した5システムのリストアテストを実施する。リストア手順書に基づき、バックアップからの復元、データ整合性チェック（チェックサム照合）、アプリケーション動作確認を行い、結果を運用部門長に報告する。

6. DRサイト構成

DRサイトは大阪DC（堂島、NTTスマートコネクスト運営）に配置し、ホットスタンバイ構成とする。大阪DCには本番環境の70%相当のサーバリソースを常時稼働させ、フェイルオーバー時には残り30%をAWS大阪リージョン（ap-northeast-3）のEC2インスタンスで補完する。

勘定系データベースは東京DC-大阪DC間でPostgreSQL同期レプリケーション（Patroni管理）を構成し、データロスゼロを実現する。レプリケーション遅延は通常1ms以下であり、閾値5msを超過した場合はアラートを発報する。ネットワーク遅延は専用線経由で片道約5ms（東京-大阪間）で

ある。

AWSのクロスリージョン災害対策として、S3バケットのクロスリージョンレプリケーション（東京→大阪）、RDSのクロスリージョンリードレプリカ（東京→大阪）、およびRoute 53ヘルスチェックによるDNSフェイルオーバーを構成する。CloudFormation StackSetsにより、大阪リージョンの環境を東京リージョンと同一構成で維持する。

大阪DCの設備は東京DCと同等の耐震・電源・空調・セキュリティ要件を満たすものとし、年次の設備点検にて確認する。大阪DC単独での全業務継続が可能な構成とし、東京DC全面停止時でもRTO内での復旧を保証する。

7. フェイルオーバー手順

フェイルオーバーの発動判断は、(1)自動判定および(2)手動判定の2方式を併用する。自動判定はPrometheus + Alertmanagerによる死活監視で実装し、主系サイトのヘルスチェックが5分以上連続で失敗した場合に自動フェイルオーバーを開始する。手動判定は運用部門長またはCSIRT責任者の承認により発動する。

DNS切替はRoute 53のヘルスチェック連動フェイルオーバーレコードにより自動実行される。TTLは60秒に設定しており、DNS伝搬完了までの想定時間は5分以内である。切替前にはAWS Lambda関数により大阪DC側のサービス正常性を自動確認し、異常がある場合はフェイルオーバーを中断してアラートを発報する。

データベースのフェイルオーバーはPatroniによる自動昇格で実行される。手順は次のとおりである。(1) Patroniが東京DCプライマリの障害を検知、(2)

大阪DC同期スタンバイをプライマリに昇格（所要時間約30秒）、(3)

アプリケーション接続先のPgBouncer設定を自動更新、(4) 接続プールのリセットと再接続、(5) トランザクション整合性の自動検証。

フェイルオーバー完了後、運用チームは以下の確認を実施する。(1)

全サービスのヘルスチェック確認、(2)

トランザクション処理の正常性確認（テスト取引の実行）、(3)

外部接続先（全銀ネット・日銀ネット等）との疎通確認、(4) 顧客向けチャネルの動作確認。確認完了をもってフェイルオーバー完了とし、経営層に報告する。

8. 復旧手順

復旧（フェイルバック）は主系サイトの障害原因が完全に解消された後に実施する。フェイルバックの開始には運用部門長および関連部門長の合意を要し、原則として業務影響の少ない夜間・休日に実施する。

復旧の優先順位はBIAに基づき、Sランク→Aランク→Bランク→Cランクの順とする。各システムの復旧手順は個別の復旧手順書（Run Book）に記載し、年次で見直しを行う。復旧手順書はConfluence上で管理し、オフラインアクセス用にPDF版を大阪DCにも配備する。

データ整合性検証は復旧プロセスの最重要ステップとして位置づける。検証手順は、(1)

DR期間中のトランザクションログの完全性確認、(2) 主系DBとDR系DBのデータ照合（pg_checksumおよびアプリケーションレベルの整合性チェック）、(3) 勘定残高の突合、(4) 監査証跡の連続性確認とする。不整合が検出された場合は復旧を中断し、手動補正手順に移行する。

フェイルバック完了後は、(1) 全サービスの動作確認、(2) レプリケーションの再構成、(3) バックアップジョブの再開、(4) 監視設定の復元を実施し、通常運用体制への移行を完了する。フェイルバックの実施記録は障害報告書に含め、改善事項を次回のBCP見直しに反映する。

9. DR訓練

DR訓練は年2回（6月・12月）の本格訓練と、四半期ごと（3月・6月・9月・12月）のリストアテストで構成する。本格訓練では実際のフェイルオーバーを実施し、RTO/RPO達成状況、フェイルオーバー手順の有効性、および関係者の対応能力を検証する。

訓練シナリオは毎回異なるパターンを採用し、(1)東京DC全面停止、(2)ネットワーク障害によるDC間通信断、(3)ランサムウェアによるデータ暗号化、(4)クラウドサービス障害等を想定する。シナリオはリスク管理部が策定し、訓練参加者には事前に詳細を通知しないブラインド方式で実施する場合もある。

訓練結果は以下の項目で評価する。(1) RTO達成状況（目標時間内に復旧完了したか）、(2) RPO達成状況（データロスが許容範囲内か）、(3) 手順書の正確性（手順書どおりに作業が実施できたか）、(4) コミュニケーション（連絡網が正常に機能したか）、(5) 改善事項の抽出。評価結果はリスク管理委員会に報告する。

四半期リストアテストでは、ランダムに選定した5システムのバックアップからのリストアを実施する。リストア後のデータ整合性チェック、アプリケーション起動確認、およびリストア所要時間の計測を行う。過去4回のテストではすべて目標時間内にリストアが完了しており、直近のテスト（2024年9月）では平均リストア時間45分であった。

10. コミュニケーション計画

災害発生時の連絡網は、第1報（発生認知から15分以内）→第2報（状況確認後30分以内）→定時報告（1時間ごと）の3段階で構成する。第1報はシステム運用チームからCSIRT責任者、運用部門長、リスク管理部長に同時発信し、緊急連絡用の専用電話回線（災害時優先電話）およびSMS配信サービスを併用する。

社内コミュニケーションはMicrosoft Teams（プライマリ）およびSlack（セカンダリ）を使用し、災害時専用チャンネルにて情報を集約する。両ツールが利用不可の場合は、衛星電話（Iridium端末3台配備）による音声連絡にフォールバックする。連絡先一覧は四半期ごとに更新し、紙媒体の緊急連絡簿を各部門に配備する。

外部連絡先として、金融庁（システムリスク管理部門）、日本銀行、全銀ネット、NTTデータ（基幹系ベンダー）、AWS（エンタープライズサポート TAM）の緊急連絡先を維持する。顧客向けの広報対応は広報部が担当し、Webサイト掲示、SNS発信、コールセンター対応スクリプトの3チャンネルで情報提供する。

全社BCP訓練時には連絡網の動作確認も実施し、第1報の到達率95%以上、到達時間15分以内を目標とする。直近の訓練（2024年12月）では到達率98.7%、平均到達時間8分であった。未達者に対しては連絡先情報の更新を依頼し、次回訓練での改善を確認する。